BIP-353 DNS Payment Instructions

SatsPath can resolve **DNSSEC-backed BIP-353 payment instructions** for domains the receiver controls. A receiver publishes a `bitcoin:` URI in DNS; any SatsPath-compatible client can then resolve `user@domain` without the sender having the receiver locally registered.

> **Mainnet Preview only.** This is a resolver/publisher layer. SatsPath does not execute mainnet payments. It resolves, verifies, routes, and displays payment instructions — it never pays, signs, or broadcasts.

What BIP-353 is

BIP-353 defines human-readable Bitcoin payment names of the form `user@domain`, resolved through DNSSEC-signed DNS `TXT` records.

- Records live at: `<user>.user._bitcoin-payment.<domain>`
- The `TXT` RDATA reconstructs into a `bitcoin:` URI (BIP-321 payment instructions).
- All payment instructions **must** be DNSSEC-signed.

Example:

```
rodrigo.user._bitcoin-payment.satspath.dev TXT "bitcoin:?lno=lno1..."
```

How SatsPath uses it

```
 rodrigo@satspath.dev   parse   rodrigo.user._bitcoin-payment.satspath.dev
                                              DNSSEC-validated TXT lookup

                            bitcoin:?lno=lno1...   (BIP-321 URI)
                                              parse + screen

                        Bip353Resolution → Mainnet-Preview QuoteResponse
```

CLI:

```
satspath dns resolve  rodrigo@satspath.dev
satspath dns resolve rodrigo@satspath.dev --json
```

Resolution rules SatsPath enforces (per BIP-353):

- Reconstruct a `TXT` record by concatenating its `<=255`-byte character-strings in RDATA order, **without separators**. Never concatenate across records.
- Ignore `TXT` records that do not begin with `bitcoin:`.
- If **more than one** `bitcoin:` record exists at the same name, the result is **invalid**.
- The payload must parse as a valid BIP-321 URI and must contain **no private material**.
- Do not cache longer than the DNS TTL.
- Prefer displaying verified names as `user@domain`.

DNSSEC requirement (fail closed)

BIP-353 payment instructions are only trustworthy if DNSSEC-validated. SatsPath **does not trust an upstream resolver's AD bit** — that can be spoofed by a malicious resolver.

`DnssecPolicy` has two modes:

Mode	Behavior
`Strict` (default)	Require real DNSSEC validation; **fail closed** otherwise.

Mode	Behavior
`DevInsecure`	Local testing only. Accept unvalidated records with loud warnings. Never the default; requires `--allow-insecure-dns-for-dev`.

This build does not ship a local DNSSEC validator, so `Strict` resolution **fails closed** with a clear message (option C of the BIP-353 DNSSEC guidance). A future release can plug in a validating resolver without changing the contract. The `--allow-insecure-dns-for-dev` flag prints a scary warning and must never be used on mainnet.

Direct TXT model (Option A)

The receiver controls their domain and publishes the record directly:

```
Name:
rodrigo.user._bitcoin-payment.satspath.dev

TXT:
bitcoin:?lno=lno1...
```

- **Pros:** simple, direct, no platform dependency.
- **Cons:** the receiver must update DNS whenever payment instructions change.

Managed CNAME/DNAME delegation model (Option B)

The receiver delegates the BIP-353 label once to a SatsPath-managed zone, which then maintains the `TXT`:

```
On example.com (added once by the receiver):
rodrigo.user._bitcoin-payment.example.com CNAME rodrigo.user._bitcoin-payment.satspath.dev

On satspath.dev (SatsPath-managed):
rodrigo.user._bitcoin-payment.satspath.dev TXT "bitcoin:?lno=lno1..."
```

- Both the receiver's domain chain **and** the managed zone must be DNSSEC-signed.
- The CNAME/DNAME chain must be DNSSEC-validated; resolution **fails closed** if not.
- **Pros:** the receiver configures DNS once; SatsPath can rotate instructions safely.
- **Cons:** requires trust in SatsPath managed-DNS availability; SatsPath must secure its DNS-provider API credentials (never committed).

Why Gmail-style emails cannot be verified through BIP-353

BIP-353 requires publishing a DNS record under the **domain** of the name. A user of `rodrigo@gmail.com` cannot publish `rodrigo.user._bitcoin-payment.gmail.com` because they do not control `gmail.com`.

> SatsPath can resolve DNSSEC-backed BIP-353 payment instructions for domains the receiver controls. For consumer email addresses like `gmail.com`, SatsPath uses platform verification / the invite flow instead, because the user cannot publish DNS records under `gmail.com`.

Rotating payment instructions

DNS record changes require a **cryptographic identity-key signature** — never email login alone.

```
1. The receiver holds their SatsPath identity key locally.
2. The platform builds a challenge:
   satspath-dns-update:<alias>:<dns_name>:<sha256(new_uri)>:<nonce>:<expires_at>
3. The receiver signs the challenge with their identity key.
```

```
4. The platform verifies the signature against the profile's identity_pubkey.
5. The platform updates the DNS TXT record via the DnsPublisher adapter.
6. The platform records an audit entry:
   { alias, dns_name, old_uri_hash, new_uri_hash, timestamp, identity_fingerprint }.
```

Email verification may gate **account access**, but DNS payment-instruction changes always require identity proof.

TTL recommendations

Instruction kind	TTL
Rotating on-chain address	300 seconds
Reusable BOLT12 offer / Silent Payment	1800 seconds

A direct on-chain address in a record is treated as **rotating** and emits a privacy warning at publish time.

BIP-321 payload handling

A resolved record is parsed as BIP-321 payment instructions. Supported:

- on-chain address in the URI path
- `amount` query parameter
- `lightning` (BOLT11 invoice)
- `lno` (BOLT12 offer)
- `sp` (Silent Payment, **preview-only**)
- unknown non-`req-*` parameters are ignored safely
- unknown `req-*` parameters make the URI **invalid**

Optional SatsPath profile pointer extension

For richer SatsPath data without breaking BIP-321, a record may carry a **non-required** key:

```
sp-profile=https%3A%2F%2Fsatspath.dev%2F.well-known%2Fsatspath%2Frodrigo
sp-profile-hash=<sha256>
```

Wallets that don't understand SatsPath ignore it. SatsPath can use it to fetch the signed profile **after** BIP-353 verifies the domain.

Security checklist

- ☒ DNSSEC required; `Strict` fails closed (no AD-bit trust).
- ☒ Multiple `bitcoin:` records at one name → invalid.
- ☒ Non-`bitcoin:` `TXT` records ignored.
- ☒ Unknown `req-*` parameters → invalid.
- ☒ Private material (`seed`, `xprv`/`tprv`, `mnemonic`, `macaroon`, `cert`, `api_key`, `claim_key`, `refund_key`, `preimage`, …) rejected before publish and on resolve.
- ☒ DNS updates require identity-key signatures; email-only rejected.
- ☒ DNS-provider credentials never committed (trait + `MockDnsPublisher` only).
- ☒ On-chain addresses use short TTL + rotation warning.
- ☒ No funds moved, no signing, no broadcast — **Mainnet Preview only**.

Example: Mainnet Preview

```
satspath preview  rodrigo@satspath.dev 1000 --mainnet
```

Expected:

```
DNSSEC: valid
BIP-353: resolved
Payment URI: bitcoin:?lno=...
Mode: Mainnet Preview
No funds moved.
```